

Shields Up and Nessus

What Did I Do?

This assignment involved two complementary vulnerability scanning tools, Shields Up by Gibson Research Corporation (GRC) and Tenable Nessus Essentials, to assess the security posture of CLIENT, a small investment management firm. The Nessus scan was conducted with the organization's permission. Together, these tools provided both external and internal perspectives on network exposure and security configuration.

Shields Up

Shields Up, developed and hosted by Gibson Research Corporation at grc.com, is a free web-based port scanning service designed to evaluate the external visibility of a computer or network from the perspective of the open internet. Unlike internal scanning tools that run from inside the network, Shields Up operates entirely from GRC's remote servers, probing the target IP address in exactly the same way a malicious actor would during the reconnaissance phase of an attack. This makes it a realistic and accurate simulation of what an adversary actually sees before deciding whether and how to attempt a breach. The tool requires no software installation and no configuration on the part of the user; upon visiting the site, it automatically detects the public-facing IP address of the current connection and is ready to begin scanning immediately.

The core output of Shields Up is a port status assessment. Every probed TCP port falls into one of three categories. An Open port is the most dangerous result, it means the port is actively listening and accepting incoming connections from the internet, advertising a running service to anyone who looks. A Closed port is less immediately dangerous but still reveals that the host exists; it returns a rejection response to the inbound probe, which confirms to a scanner that the machine is present and reachable even if that particular service is not running. A Stealth port is the ideal and most secure state, the host ignores the probe entirely, returns no response, and appears to any outside scanner as if both the port and the machine do not exist at all. GRC refers to a network where every tested port achieves Stealth status as having a perfect TrueStealth rating, meaning the system is effectively invisible to internet-based attackers and automated scanning tools.

Two scan modes were used for this assessment. The Common Ports scan tests a focused set of the most frequently attacked service ports, including those used by FTP (port 21), SSH (22), Telnet (23), SMTP (25), DNS (53), HTTP (80), HTTPS (443), and several others that attackers routinely probe during initial network mapping. This scan is faster and gives a quick read on the most critical and commonly exploited exposure points. The All Service Ports scan is more comprehensive, testing all 1,056 TCP ports in the service range and producing a color-coded grid where each cell represents a single port: green for Stealth, red for Open, and blue for Closed. Both scans were run against the network's public IP address, 216.97.251.199, and results were captured via screenshot for this report. The All Service Ports scan completed in approximately 69 seconds.

Nessus Essentials

Tenable Nessus Essentials is the free, limited-capability edition of Nessus, one of the most widely used and well-regarded vulnerability scanners in the cybersecurity industry. While Shields Up operates from the outside looking in, Nessus is deployed inside the network and examines systems from a position of local access, making it capable of detecting a much broader and deeper range of issues than port status alone. The Essentials version is licensed for up to 16 IP addresses per scan, which is appropriate for small business and home lab environments, and is available to students and individuals at no cost through Tenable's website. The commercial versions of Nessus extend its capabilities to include compliance auditing, large-scale credentialed patch assessment, integration with enterprise ticketing systems, and full reporting functionality, but the Essentials version is sufficient to identify the most common and impactful vulnerability classes across a small network.

Nessus operates by running a large, continuously updated library of detection plugins against each host in the scan scope. Each plugin targets a specific vulnerability, misconfiguration, or information disclosure condition: checking for things like outdated software versions, weak cryptographic configurations, exposed and unnecessarily open services, missing security patches, default or weak credentials, and insecure protocol settings. When Nessus confirms a finding, it cross-references it against three established scoring frameworks. CVSS, the Common Vulnerability Scoring System, rates the technical severity of a vulnerability on a 0-to-10 scale based on factors like exploitability, attack complexity, and the potential impact on confidentiality, integrity, and availability. VPR, Tenable's proprietary Vulnerability Priority Rating, incorporates real-world threat intelligence, including active exploit availability and recent threat actor behavior, to produce a score that reflects actual current risk rather than theoretical severity alone. EPSS, the Exploit Prediction Scoring System, estimates the probability that a given vulnerability will be actively exploited in the wild within the next 30 days. Together, these three scores give a more complete and actionable picture of risk than any single number could provide.

For this assessment, Nessus was configured as a Basic Network Scan targeting the internal network range at CLIENT. The scan ran without credentials, meaning Nessus did not authenticate to any of the target hosts with a username and password. This limits its ability to assess operating system patch levels and enumerate installed software, since that information is only accessible once a scanner has logged into the system. In a professional engagement, credentialed scans are the standard because they allow Nessus to inspect systems from the inside, reading configuration files, querying installed software registries, and comparing version numbers against CVE databases. This limitation was a consequence of the student license and the scan configuration chosen, and it is worth noting that a credentialed scan of the same network would likely surface additional findings. The scan returned 31 total findings across three severity tiers: MIXED, LOW, and INFO. Because the Essentials license does not permit PDF export or automated report generation, the results were documented via screenshot and analyzed manually.

What Are the Results

The Nessus scan of CLIENT's network returned 31 total findings. No CRITICAL or HIGH severity vulnerabilities were detected, which represents a positive baseline and suggests the organization is not running obviously exploitable services. However, several findings warrant attention, particularly given the financial services context, where data confidentiality obligations and regulatory expectations around cybersecurity are elevated. The Shields Up external scan produced the best possible result, confirming that the network perimeter is well-hardened against outside reconnaissance.

Shields Up Results

The All Service Ports scan was run against the public IP address 216.97.251.199. The results were as strong as they can be: every one of the 1,056 tested TCP ports returned a Stealth status, shown in the output as a completely solid green grid with zero red or blue cells present. Shields Up confirmed that not a single packet was returned from the network in response to any probe, including repeated ICMP ping requests designed to test whether the host would reveal itself. The tool awarded a perfect TrueStealth rating, and its full conclusion read as follows:

TrueStealth Result	"Your system has achieved a perfect TrueStealth rating. Not a single packet — solicited or otherwise — was received from your system as a result of our security probing tests. Your system ignored and refused to reply to repeated Pings (ICMP Echo Requests). From the standpoint of the passing probes of any hacker, this machine does not exist on the Internet." — GRC Shields Up, total elapsed testing time: 69.105 seconds
--------------------	--

This result confirms that the network's perimeter router or firewall is correctly configured to silently drop all unsolicited inbound packets without acknowledgment. No ports are being forwarded to internal hosts, and the public-facing IP presents zero detectable attack surface to external scanners. This is the ideal outcome for an organization's internet-facing perimeter and means that an attacker conducting automated or manual reconnaissance from the internet would find nothing to work with at the network edge.

Nessus Findings Summary

Severity	Finding	Family	Count	Priority
MIXED	SSL (Multiple Issues)	General	6	Immediate — remediate first
LOW	DHCP Server Detection	Service Detection	1	Monitor / Accept Risk

Severity	Finding	Family	Count	Priority
LOW	ICMP Timestamp Request Remote Date Disclosure	General	1	<i>Configure firewall rule</i>
INFO	Remote Svcs Not Using Post-Quantum Ciphers	General	3	<i>Plan migration timeline</i>
INFO	Shor's Harvest Now Decrypt Later	General	1	<i>Begin PQC roadmap</i>
INFO	OS Security Patch Assessment Not Available	Settings	1	<i>Provide scan credentials</i>
INFO	TLS (Multiple Issues)	General	3	<i>Review cipher suites</i>
INFO	DNS (Multiple Issues)	DNS	3	<i>Audit DNS configuration</i>
INFO	SSH (Multiple Issues)	Service Detection	2	<i>Review SSH algorithms</i>
INFO	HTTP (Multiple Issues)	Web Servers	2	<i>Review HTTP headers/config</i>
INFO	ISC Bind (Multiple Issues)	DNS	2	<i>Patch/update BIND</i>

Key Finding Analysis

SSL (Multiple Issues) — MIXED Severity

This is the most significant finding in the scan and should be addressed first. The MIXED severity designation indicates that the sub-findings grouped under this category span more than one severity level: some are moderate, others may be lower, and collectively they represent the broadest and most consequential security gap on the network. SSL and TLS issues commonly include the use of deprecated protocol versions such as SSL 3.0 or TLS 1.0 and 1.1, which have known cryptographic weaknesses and are no longer considered secure; weak cipher suites such as RC4, 3DES, or export-grade ciphers that can be broken by modern computing resources; self-signed or expired certificates that cannot be trusted by connecting clients; and certificates signed with outdated algorithms such as SHA-1. Six instances were detected across the network. The practical risk is substantial, an attacker who can position themselves between a client and a server can exploit weak SSL and TLS configurations to intercept and decrypt traffic in transit, impersonate services, or inject malicious content into sessions. For an investment management firm that handles client financial data, account access, and confidential correspondence over encrypted channels, ensuring that encryption is current and correctly

configured is not optional. It is a baseline expectation under SEC cybersecurity disclosure requirements, state-level financial data protection statutes, and general duty-of-care obligations to clients.

Recommended remediation: All network devices and services should be configured to disable SSL 3.0 and TLS versions 1.0 and 1.1, enforcing TLS 1.2 at a minimum with TLS 1.3 preferred wherever supported. Self-signed or expired certificates should be replaced with valid certificates from a trusted certificate authority. Cipher suite configurations should be reviewed and any weak or deprecated ciphers removed from the allowed list.

ICMP Timestamp Request Remote Date Disclosure — LOW (CVSS 2.1)

This vulnerability allows a remote attacker to learn the internal clock value of a network host by sending ICMP timestamp request packets (type 13) and reading the timestamp reply (type 14) that the system returns. While the direct severity is low, attackers use time disclosure to refine host fingerprinting, correlate event logs across multiple systems, and improve the accuracy of certain time-sensitive attacks. The EPSS score of 0.0037 indicates a very low probability of active exploitation in the wild, and on its own this finding poses minimal operational risk. However, the fix is simple enough, a single firewall rule, that remediation is advisable regardless. It is worth noting that the Shields Up scan confirmed the network already drops standard ICMP echo requests (pings), which is good; ICMP timestamp requests are a distinct packet type, however, and may be handled differently depending on the specificity of the existing firewall rules.

Recommended remediation: The network firewall or host-based firewall should be configured to block inbound ICMP timestamp requests (type 13) and outbound timestamp replies (type 14). On Linux systems this is accomplished with iptables or nftables rules targeting ICMP type 13; on Windows, the Windows Firewall with Advanced Security can block ICMP type 13 messages specifically.

Remote Services Not Using Post-Quantum Ciphers / Shor's Harvest Now Decrypt Later — INFO

These two findings are closely related and together represent a forward-looking risk that is gaining real urgency across the cybersecurity industry. Three services on the scanned network were flagged as not supporting post-quantum cryptographic algorithms. The Shor's Harvest Now Decrypt Later finding references a specific and well-documented threat strategy in which adversaries capture and store encrypted network traffic today, even traffic they have no ability to currently decrypt, with the intention of decrypting it once sufficiently powerful quantum computers become available, a timeline that most researchers now estimate at somewhere between ten and twenty years. For an investment management firm that handles client financial records, account details, and confidential transaction data that may need to remain private for decades, this is a meaningful strategic risk even if it is not an immediate operational emergency. NIST finalized its first post-quantum cryptography standards in 2024, including the ML-KEM and

ML-DSA algorithms, and major operating systems and cloud platforms are beginning to add native support.

Recommended remediation: The organization should begin tracking NIST's post-quantum cryptography standards and develop a multi-year migration roadmap for services that handle sensitive and long-lived data. This is a planning and roadmap item rather than an emergency fix, but it should be documented and revisited as the broader industry's PQC transition accelerates over the next several years.

OS Security Patch Assessment Not Available — INFO

Nessus was unable to assess the operating system patch status of scanned hosts because the scan ran without credentials. Patch assessment is one of the most valuable capabilities a vulnerability scanner can provide, it compares the installed software and OS patch levels on each host against a database of known CVEs and flags anything that is out of date or unpatched. Without the ability to authenticate to the host, Nessus cannot access the internal software inventory it needs to make that comparison, which creates a meaningful blind spot in the results. This finding reflects a limitation of the scan configuration rather than a confirmed security failure, but it means that unpatched operating systems, outdated applications, or known vulnerable software versions could exist on the network without detection. In a production security assessment this would be treated as a critical gap, not a minor informational note.

Recommended remediation: For future scans, Nessus should be provided with local administrator credentials for the target hosts so that authenticated scanning can be performed. This single change would substantially increase the depth and accuracy of results, and patch compliance is an area where even small organizations are frequently exposed.

DNS, TLS, HTTP, SSH, and ISC Bind (Multiple Issues) — INFO

These grouped informational findings collectively flag configuration details and potential weaknesses across several active services on the network. In the DNS category, common issues include DNS zone transfers being enabled without restriction, which can expose the complete list of internal hostnames and IP addresses to any external requester — effectively providing an attacker with a map of the internal network. In the SSH category, weak key exchange algorithms such as diffie-hellman-group1-sha1 are flagged; these are considered cryptographically insufficient by current standards and have been deprecated in most modern SSH implementations. HTTP findings typically include missing security headers such as X-Frame-Options, which protects against clickjacking attacks, and Content-Security-Policy, which limits what resources a browser will load from a page. The ISC Bind findings flag a DNS server software version that may have known CVEs in its release history. While all of these are classified as INFO, meaning they were not confirmed as directly exploitable in the unauthenticated scan context, each represents a configuration gap that a more targeted attacker could investigate and leverage as part of a broader attack chain.

Recommended remediation: A system administrator should review each flagged service's configuration against current hardening benchmarks such as the CIS Benchmarks or applicable DISA STIGs. Unnecessary services should be disabled, DNS zone transfers should be restricted to authorized secondary DNS servers only, SSH should be configured to allow only modern key exchange algorithms, and all server software should be updated to currently supported and patched versions.

What Did I Learn

The Layered Nature of Vulnerability Scanning

One of the most important takeaways from this assignment was seeing how differently two scanning tools characterize the same network. Shields Up provided an attacker's external view, what is visible and reachable from the internet before any authentication or internal access is involved; while Nessus provided an internal diagnostic view of service configurations, protocol settings, and known weakness patterns on hosts inside the network. The two tools are genuinely complementary: Shields Up confirmed that the network perimeter is solid and presents no detectable external attack surface, while Nessus revealed that several internal service configurations still have areas for improvement. Together they paint a more accurate picture than either could alone. Real-world security assessments build on this further by combining external reconnaissance scanning, internal authenticated scanning, manual penetration testing, and ongoing threat intelligence monitoring to develop a truly comprehensive understanding of risk.

The Difference Between Severity and Priority

This assignment reinforced that raw severity scores do not automatically translate into remediation priority. The ICMP timestamp vulnerability, for example, carries a CVSS score of only 2.1 and an EPSS probability of less than half a percent, but it is trivially remediable with a single firewall rule and carries essentially no remediation cost or risk. The SSL issues, by contrast, are labeled MIXED, meaning their sub-findings span a range of severity levels, but they represent by far the most operationally significant risk on the network given their potential to expose client communications and financial data to interception. Prioritizing solely by CVSS score would lead a security team to spend time on low-impact items while more consequential risks go unaddressed. Effective triage requires accounting for the exploitability of the finding, the sensitivity of the data it could expose, the complexity of the fix, and the organization's specific regulatory and operational context. Score sorting is a starting point, not a decision.

Authenticated vs. Unauthenticated Scanning

Running Nessus without credentials produced a meaningful gap in results: specifically, the inability to assess operating system patch levels or enumerate installed software on any of the scanned hosts. In a professional engagement, credentialed scans are the standard practice because they allow the scanner to authenticate to each host as an administrator and inspect the system from the inside, reading configuration files, querying installed software registries, and

comparing version numbers against the CVE database. The difference in finding depth between a credentialed and an uncredentialed scan of the same host can be substantial — a credentialed scan may return several times as many findings because it has access to information that is simply not visible from the network layer. Encountering this limitation firsthand was a useful and practical lesson in how scan scope and access level directly determine the quality and completeness of results, and it will inform how I approach future assessments.

Post-Quantum Cryptography Is No Longer a Future Problem

The presence of both the Remote Services Not Using Post-Quantum Ciphers and the Shor's Harvest Now Decrypt Later findings in a scan of a small investment management firm was a concrete illustration of how quickly post-quantum concerns are moving from theoretical to operational. NIST finalized its first post-quantum cryptography standards in 2024, and the broader cybersecurity community is in the early stages of a transition that will eventually affect every organization that transmits sensitive data over the internet. The Harvest Now, Decrypt Later threat model is particularly relevant for financial services firms because the data they handle, client account numbers, investment positions, identity information, and financial transaction records, may retain its sensitivity and value for many years or even decades. Seeing these findings surface in a Nessus Essentials scan of a small business reinforced that post-quantum readiness is no longer a concern limited to government agencies and large enterprise environments. It is a planning item that every organization handling long-lived sensitive data should begin to address.

Value to an Organization

For an organization like CLIENT, a financial services firm handling sensitive client assets and personal financial data, regular vulnerability scanning provides critical and concrete business value that goes well beyond the findings of any single scan. It gives the organization continuous visibility into its attack surface, which is especially important as new devices, services, and software are added to the network over time. It enables early detection of misconfigured services before those misconfigurations can be discovered and exploited; the SSL weaknesses identified in this scan, for instance, could expose encrypted client communications without the firm ever being aware the channel had been compromised. Regular scanning also produces documentation that can support the organization's regulatory obligations, including SEC cybersecurity disclosure requirements and state-level financial data protection statutes, by demonstrating that the organization is actively assessing and managing its security posture rather than waiting for an incident to reveal gaps. For a small firm without a dedicated IT security staff, tools like Nessus Essentials are particularly valuable because they bring enterprise-grade detection capability to organizations that could not otherwise afford a formal vulnerability management program. Each subsequent scan can be compared to the previous one, showing which findings have been remediated and whether new ones have appeared, giving leadership a concrete and measurable way to track security improvement over time.

Vulnerability scanning is most valuable when performed regularly and when findings are tracked and remediated systematically rather than addressed reactively or ignored. For CLIENT, the SSL findings represent the most pressing near-term action item and should be treated as a

priority given the nature of the data the firm handles. The post-quantum findings are a longer-horizon concern but one that should be formally documented and revisited annually as the industry's PQC transition continues. Tools like Nessus Essentials provide an accessible and powerful starting point for organizations at any scale, enabling informed, evidence-based security decisions that were previously available only to firms with dedicated security budgets and staff.